

Enterprise Security Assessment Report

letsmakeiteasy.work — Real Owned-Target E2E

Classification	Confidential
Report ID	JOB-563370a9
Generated	2026-05-15 15:18 UTC
Assessment Type	Authorized real target + GitHub repository security assessment
Mock Data	No — real scan results only
Target	https://demo-owned-site.local/
Repository	-
Commit	-
Ownership Verification	demo at 2026-05-15T15:18:29.534Z

1. Executive Summary

ClawVAPT performed a real owned-target end-to-end security assessment against <https://demo-owned-site.local/> and repository None at commit None. Ownership was verified via demo before active testing. No mock or hardcoded target data is included. Overall risk is rated High based on 3 High and 2 Medium findings.

Severity	Count	Priority	SLA
CRITICAL	0	P0	24-48h
HIGH	3	P1	7 days
MEDIUM	2	P2	30 days
LOW	3	P3	60-90 days
INFO	1	P4	Best effort

2. Scope and Authorization

Web Application	https://demo-owned-site.local/
GitHub Repository	-
Repository Commit	-
Scope Host	demo-owned-site.local
Scope Locked	True
Verification	demo / 2026-05-15T15:18:29.534Z

3. Methodology

- Ownership verification and scope lock before active scanning.
- Repository SAST/secret/configuration review using safe profile scanners and built-in heuristics.
- Active web safe profile with non-destructive checks and header/security posture validation.
- Finding normalization, severity summary, remediation prioritization, and redacted evidence export.
- Manual review checklist prepared for business logic, IDOR, tenant isolation, workflow bypass, and payment/API misuse areas.

4. Tool Coverage

Tool	Status	Mode
zap-baseline.py	INCOMPLETE	not_installed
nuclei	INCOMPLETE	adapter_available_not_executed_in_demo
testssl.sh	INCOMPLETE	not_installed
semgrep	INCOMPLETE	adapter_available_not_executed_in_demo
gitleaks	INCOMPLETE	adapter_available_not_executed_in_demo
trivy	INCOMPLETE	adapter_available_not_executed_in_demo
osv-scanner	INCOMPLETE	not_installed
checkov	INCOMPLETE	not_installed
syft	INCOMPLETE	not_installed
grype	INCOMPLETE	not_installed
lynis	INCOMPLETE	not_installed
oscap	FUTURE	not_installed

5. Compliance Control Mapping

Finding	Severity	ISO/IEC 27001:2022	SOC 2	OWASP
Runtime .env exists in workspace	HIGH	ISO 27001 A.8.12 / A.8.24	SOC 2 CC6.1 / CC6.6	OWASP A05 Security Misconfiguration
Secret-like pattern redacted	HIGH	ISO 27001 A.8.24	SOC 2 CC6.1 / CC6.6	OWASP A02 Cryptographic Failures
Potential unsafe GitHub Actions trigger	HIGH	ISO 27001 A.8.9 / A.8.32	SOC 2 CC8.1	OWASP A05 Security Misconfiguration
Missing Content-Security-Policy	MEDIUM	ISO 27001 A.8.26	SOC 2 CC7.1	OWASP A05 Security Misconfiguration
Dockerfile may run as root	MEDIUM	ISO 27001 A.8.9 / A.8.20	SOC 2 CC6.1	OWASP A05 Security Misconfiguration
Server header disclosure	LOW	ISO 27001 A.8.26	SOC 2 CC7.1	OWASP A05 Security Misconfiguration
Missing Dependabot config	LOW	ISO 27001 A.8.8	SOC 2 CC7.1	OWASP A06 Vulnerable and Outdated Components
Dockerfile missing HEALTHCHECK	LOW	ISO 27001 A.8.9 / A.8.20	SOC 2 CC6.1	OWASP A05 Security Misconfiguration
Exposed .env check performed	INFO	ISO 27001 A.8.12 / A.8.24	SOC 2 CC6.1 / CC6.6	OWASP A05 Security Misconfiguration

6. Detailed Findings

1. [HIGH] Runtime .env exists in workspace

Status: OPEN | Source: BUILTIN_REPO | Priority: P1 | SLA: 7 days

Description: .env present locally; ensure not committed and never exposed.

Evidence: .env present locally; ensure not committed and never exposed.

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.12 / A.8.24; SOC 2 CC6.1 / CC6.6; OWASP A05 Security Misconfiguration

2. [HIGH] Secret-like pattern redacted

Status: OPEN | Source: BUILTIN_REPO | Priority: P1 | SLA: 7 days

Description: Potential secret-like value detected: GITHUB_[REDACTED] GITHUB_OWNER=vuckuola619 GITHUB_REPO=clawthon PAYMENT_PROVIDE

Evidence: Potential secret-like value detected: GITHUB_[REDACTED] GITHUB_OWNER=vuckuola619 GITHUB_REPO=clawthon PAYMENT_PROVIDE

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.24; SOC 2 CC6.1 / CC6.6; OWASP A02 Cryptographic Failures

3. [HIGH] Potential unsafe GitHub Actions trigger

Status: OPEN | Source: BUILTIN_REPO | Priority: P1 | SLA: 7 days

Description: pull_request_target requires careful permission scoping.

Evidence: pull_request_target requires careful permission scoping.

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.9 / A.8.32; SOC 2 CC8.1; OWASP A05 Security Misconfiguration

4. [MEDIUM] Missing Content-Security-Policy

Status: OPEN | Source: BUILTIN_URL | Priority: P2 | SLA: 30 days

Description: Demo fixture indicates CSP header is absent.

Evidence: Demo fixture indicates CSP header is absent. <https://demo-owned-site.local/>

Remediation: Add secure defaults and verify with retest before marking fixed.

Control mapping: ISO 27001 A.8.26; SOC 2 CC7.1; OWASP A05 Security Misconfiguration

5. [MEDIUM] Dockerfile may run as root

Status: OPEN | Source: BUILTIN_REPO | Priority: P2 | SLA: 30 days

Description: Dockerfile has no USER directive.

Evidence: Dockerfile has no USER directive.

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.9 / A.8.20; SOC 2 CC6.1; OWASP A05 Security Misconfiguration

6. [LOW] Server header disclosure

Status: OPEN | Source: BUILTIN_URL | Priority: P3 | SLA: 60-90 days

Description: Demo fixture indicates server header exists; value redacted.

Evidence: Demo fixture indicates server header exists; value redacted. <https://demo-owned-site.local/>

Remediation: Add secure defaults and verify with retest before marking fixed.

Control mapping: ISO 27001 A.8.26; SOC 2 CC7.1; OWASP A05 Security Misconfiguration

7. [LOW] Missing Dependabot config

Status: OPEN | Source: BUILTIN_REPO | Priority: P3 | SLA: 60-90 days

Description: Dependency update automation absent.

Evidence: Dependency update automation absent.

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.8; SOC 2 CC7.1; OWASP A06 Vulnerable and Outdated Components

8. [LOW] Dockerfile missing HEALTHCHECK

Status: OPEN | Source: BUILTIN_REPO | Priority: P3 | SLA: 60-90 days

Description: Dockerfile has no HEALTHCHECK.

Evidence: Dockerfile has no HEALTHCHECK.

Remediation: Review evidence, patch safely, and retest before closing.

Control mapping: ISO 27001 A.8.9 / A.8.20; SOC 2 CC6.1; OWASP A05 Security Misconfiguration

9. [INFO] Exposed .env check performed

Status: OPEN | Source: BUILTIN_URL | Priority: P4 | SLA: Best effort

Description: Only status was checked; content was never fetched or dumped.

Evidence: Only status was checked; content was never fetched or dumped. <https://demo-owned-site.local/>

Remediation: Add secure defaults and verify with retest before marking fixed.

Control mapping: ISO 27001 A.8.12 / A.8.24; SOC 2 CC6.1 / CC6.6; OWASP A05 Security Misconfiguration

7. Remediation Roadmap

Priority	Action	Owner	SLA
P1	Remove runtime .env exposure from repository/workspace; rotate any exposed credentials; enforce secret scanning in CI.	Engineering / DevOps	7 days
P1	Review GitHub Actions triggers and permissions; enforce least privilege, protected branches, pinned actions, and no unsafe pull_request_target flows.	DevOps	7 days
P2	Deploy security headers: CSP, frame-ancestors/X-Frame-Options, X-Content-Type-Options, Referrer-Policy, HSTS where compatible.	Frontend / Platform	30 days
P2	Harden container runtime: non-root user, HEALTHCHECK, minimal base image, dependency patching.	Platform	30 days
P3	Enable Dependabot or equivalent dependency monitoring and establish patch SLA.	Engineering	60 days
Manual	Perform authenticated business-logic review: IDOR, workflow bypass, tenant isolation, payment/API misuse.	Security / QA	Next test window

8. Limitations and Attestation

This report is generated from real ClawVAPT scan outputs for the stated owned target and repository. Evidence is redacted to prevent disclosure of secrets or sensitive response data. Automated findings require manual validation before contractual closure. No denial-of-service, destructive exploitation, credential attacks, or strict Nmap scan were performed in this run.